MacZine

THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 050 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · ASSESSMENT EVIDENCE

3.3.1 Audit Logs: What the Assessor Asks For, Objective by Objective

3.3.1 is one requirement, six assessment objectives and five SPRS points. What an assessor examines, who they interview, what they test, and the evidence that satisfies each objective.

BY **PATRICK CARUSO**

READING TIME · 7 MIN

NIST-800-171 · CMMC · AUDIT-LOGGING · ASSESSMENT-OBJECTIVES · EVIDENCE

When a C3PAO assessor reaches 3.3.1 they do not ask whether you have logging. Everyone has logging. They open NIST SP 800-171A, find six lettered objectives, and ask for something specific against each one. A single objective they cannot satisfy fails the requirement, and 3.3.1 is a five-point requirement, the heaviest weight the DoD assessment methodology assigns.

Here is the direct answer. 3.3.1 has six objectives. Two are about deciding (what to log, what a record contains), two are about doing (records are generated, records contain the defined content), and two are about keeping (retention is defined, retention happens). Most programs can evidence the middle pair with a screenshot. The first pair needs a document that most programs have never written, and the last pair needs a number most programs have never chosen. This piece walks all six with the evidence that satisfies each, using our own enclave's monitoring as the worked example where it helps.

FIELD COPY
ISSUE Nº 050
NIST 800 171

6

ASSESSMENT OBJECTIVES UNDER 3.3.1 - ONE UNMET OBJECTIVE FAILS THE WHOLE REQUIREMENT

The three methods, before the objectives

800-171A gives the assessor three methods for every requirement, and 3.3.1 uses all of them.

Examine. The audit and accountability policy, the procedures addressing auditable events, the security plan, system configuration settings, and the audit logs themselves. Note that the list starts with policy and ends with logs. An assessor who examines the logs before the policy has nothing to compare them against.

Interview. People with audit responsibilities, people with security responsibilities, and the system administrators. The interview question that matters is not "do you log?" It is "how did you decide what to log?"

Test. The mechanisms implementing audit logging. Generate an event, find it in the record. This is the one method programs prepare for, and the one the assessor spends least time on.

5

SPRS POINTS 3.3.1 CARRIES, THE HIGHEST WEIGHT IN THE METHODOLOGY

191

WINDOWS AND AZURE EVENT TYPES THE MACTECH ENCLAVE'S MONITORING CATALOGUE NAMES, EACH MAPPED TO THE CONTROLS IT EVIDENCES

The assessor is not testing whether your system logs. They are testing whether you decided what it should log, and whether the system does what you decided.

◆ THE REQUIREMENT, VERBATIM

"Create and retain system audit logs and records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity." Two verbs - create and retain - and a purpose clause that decides what "enough" means.

[a] Are the event types to be logged specified?

The word is *specified*. Not enabled, not available. The assessor wants a written list of the event types your organization decided to capture, and a reason tied to the requirement's purpose clause: monitoring, analysis, investigation and reporting of unauthorized activity.

What satisfies it: a section of the audit policy, or a standalone auditable-events list, that names event categories (logon success and failure, privilege use, account management, policy change, object access to CUI, process creation, log clearing) and maps each to what it would let you detect. A Windows audit-policy export on its own does not satisfy [a], because it shows what is enabled without showing that anyone chose it.

What we do: the enclave's monitoring catalogue names 191 Windows and Azure event types, each with the event family it belongs to and the controls it evidences. The catalogue is the specification; the audit-policy configuration is the implementation of it. The assessor gets both, and can diff them.

[b] Is the content of audit records defined?

The requirement says records must enable investigation, and an investigation needs to answer who, what, when, where and from where. Objective [b] asks whether you wrote that down: which fields a record must carry.

What satisfies it: a short statement in the policy that every audit record includes a timestamp, the event type, the subject (user or process), the object acted on, the outcome, and the source (host, session, address). This is the objective 3.3.2 leans on as well, since individual accountability is impossible without the subject field.

◆ WHERE RETENTION ACTUALLY LIVES

Objectives [e] and [f] are about retention, and they are the two most programs fail. A log that is generated but rolls over in nine days has not been retained "as defined" unless your definition says nine days. The number lives in your policy, not in your tooling.

[c] Are audit records created?

The easy one. Show that the mechanism is on and producing records.

What satisfies it: an audit-policy export showing the specified subcategories enabled for success and failure, and a sample of the Security log with recent entries. For an Azure-hosted enclave, the Activity Log diagnostic setting showing delivery to a workspace.

What we do: four of the ninety-seven checks in the enclave's weekly hardening run are 3.3.1 checks. One confirms the Security log is enabled, one that the audit policy is queryable, one that the key subcategories are set for success and failure, and one that the log sizes meet the baseline. Each runs as a forensic packet with the command issued, the value expected and the value observed, hashed into a signed chain. The assessor gets a dated record that [c] was true on a given Sunday, and every Sunday before it.

[d] Do records contain the defined content?

This is where [b] comes back. Take a real record and hold it against the content definition. If the definition says every record carries the source address and your VPN concentrator's records do not, [d] fails for that system.

What satisfies it: a handful of real records, one per major log source, annotated field by field against the definition in [b]. It takes an afternoon and most programs have never done it.

[e] Are retention requirements defined?

A number, in a document. How long records are kept, and where. The requirement does not set the number; DFARS 252.204-7012 sets a floor for incident-related data (ninety days of monitoring data preserved after an incident report), and most programs choose a year for the general case because that is what the Azure and Microsoft 365 baselines make cheap.

What satisfies it: one sentence in the policy. "Audit records are retained for no less than 365 days in the central workspace and 90 days on the originating host."

What we found in our own enclave: the monitoring catalogue carried a retention field on all 191 event types, and every one of them said "per organizational SSP". That is a pointer, not a definition. The number had to be written into the SSP for [e] to be met, and until it was, the catalogue's field was decorative. This is the most common way [e] fails: everyone assumed someone else had chosen the number.

[f] Are records retained as defined?

Evidence that the number in [e] is real. The workspace retention setting, the log-size and rollover configuration on the host, and, ideally, a record older than the threshold that is still there.

What satisfies it: a screenshot or export of the retention setting where the logs live, plus a query that returns a record from near the retention boundary. For a host that rolls its Security log at a size limit, the size must be large enough that the log does not roll before it is shipped; an oversized log that overwrites itself in three days fails [f] no matter what the policy says.

A limit worth stating plainly: our enclave's monitoring service has no retention purge of its own yet. Retention for the enclave is enforced by the Azure workspace setting and by the host log sizes the hardening run checks, and the number is defined in the SSP. When the service gains its own retention policy, that will be published on its spec sheet; until then the honest evidence for [f] is the workspace and the host, not the service.

The order to do this in

If you have a week before an assessment and 3.3.1 is soft, do the objectives in this order.

1. Write the auditable-events list ([a]) and the record-content definition ([b]) into the audit policy. Two pages.
2. Choose the retention number and write it into the same policy and the SSP ([e]).
3. Export the audit policy and a log sample from every system in scope, and annotate one record per source against the content definition ([c], [d]).
4. Export the retention settings where the logs live and pull one old record ([f]).

Then read your own SSP narrative for 3.3.1 and make sure it cites those four artifacts by name. An assessor who can walk from the narrative to the policy to the export to the record is an assessor who moves on.

The full list of what our enclave's monitoring collects, how often, and what it does not claim to prove is on the EnclaveWatch spec sheet. The POA&M rules for when a control like this can be carried open are in Issue 23. ◆